

웹 공격 문자열을 이미지로 바꿔 탐지하는 2단 구조 연구

새 주 데이터셋(2020년 실서버 수집) 확보·정제와, 이미지에 넣을 입력 필드를 고르는 실험 결과

보고일 2026-09-14 · 보고 범위 2026-08-24 ~ 2026-09-14

세 줄 요약

- 데이터 확보·정제 완료** — 2020년 실서버 데이터셋(SR-BH 2020, 907,815건)을 받아 무결성을 검증하고, 14개 공격 라벨을 기존 4분류(정상·SQL 주입·코드 주입·명령 주입)로 접어 **학습용 데이터 265,939건**을 만들었습니다.
- 라벨 오류를 직접 감사했습니다** — "정상"으로 라벨된 요청 중 **30,280건(5.8%)이 실제 공격**이었습니다. 선행 논문이 보고한 오류가 실재함을 저희 손으로 확인했고, 이 요청들은 학습 데이터에서 빼되 **별도 평가 세트**로 남겼습니다.
- 입력 필드 선택 실험**(시험 데이터를 봉인한 5겹 교차검증)에서 **URI+본문+쿠키** 조합이 가장 좋았습니다 (Macro-F1 0.932). 다만 **정상 클래스가 실제 사용자가 아닌 스캐너의 탐색 요청 위주**라는 한계가 새로 드러나, 해석 범위를 좁혀 보고하겠습니다.

1. 데이터 확보와 무결성 검증

지난 보고에서确定的한 주 데이터셋을 공개 저장소(Harvard Dataverse, CC0 라이선스)에서 받았습니다. 파일 크기와 체크섬(MD5)이 배포처 값과 일치함을 확인한 뒤에만 사용하도록 다운로드 도구에 검증 단계를 넣었습니다.

항목	확인 결과
규모	907,815건 (논문 기재 907,814건보다 1건 많음 — 정상 건수는 논문과 일치)
구성	요청·응답 필드 24개 + 라벨 14개(라벨마다 0/1 컬럼, 한 요청에 여러 라벨 가능)
원문 보존	URI·본문·쿠키·User-Agent 원문 문자열이 살아 있어 이미지 변환이 그대로 가능
이상값	라벨 값 이상 0건, 라벨 없는 요청 0건, "정상"과 공격 라벨이 동시에 붙은 요청 0건

2. 라벨 구조 확인과 4분류 매핑

논문에는 라벨이 13개로 소개되어 있었는데, 실제 배포본에는 **"명령 주입(248)"** 라벨이 하나 더 있었습니다. 이 라벨은 "OS 명령 주입(88)"의 상위 범주라 매핑 규칙을 흔들 수 있어 먼저 실측했습니다. 전체에서 **단 1건뿐**이어서, "상위 범주도 해당 클래스로 본다"는 규칙으로 통일해 명령 주입에 합쳤습니다(결과 차이 1건).

원 라벨	본 연구 클래스	건수
정상	정상	525,195
SQL 주입	SQL 주입	249,227
코드 주입	코드 주입	13,838
OS 명령 주입 · 명령 주입	명령 주입	5,794
대상 클래스가 2개 이상 붙은 요청	모호 → 제외	2,381
나머지 9개 라벨만 붙은 요청(경로 조작 등)	대상 아님 → 제외 (정상으로 넣지 않음)	111,380

"코드 주입"은 XSS가 아닙니다. 원문을 확인해 보니 스크립트 삽입(XSS)이 아니라 서버 측 PHP 코드 실행을 시험하는 스캐너 요청이 대부분이었습니다. 논문에서는 이 클래스를 XSS와 동일시하지 않고 "코드 주입"으로 표기하겠습니다.

3. 라벨 오류 자체 감사

최근 논문(arXiv:2512.23610)이 이 데이터셋의 "정상" 라벨 중 **48,522건이 실제로는 공격**이라고 보고했습니다. 저희 핵심 지표(공격을 정상으로 놓치는 비율, 오탐률)는 이런 오류가 있으면 **실제보다 좋게** 나오므로, 인용하기 전에 직접 확인했습니다. 결과를 보고 기준을 바꾸지 않도록 **탐지 규칙 16개를 실행 전에 고정**했습니다.

항목	결과
"정상" 중 공격 규칙에 걸린 요청	30,280건 / 525,195건 (5.77%)
선행 논문 보고치 대비	48,522건의 62% — 오류의 실재와 수만 건 규모는 재현 , 숫자 자체는 미재현(선행은 LLM 판정으로 더 넓게 잡음)
수동 확인	걸린 요청 37건을 원문으로 확인 → 37건 모두 실제 공격 (예: 경로 중간에 <code>;cat /etc/passwd;</code> , <code>sleep(15)</code> 주입)
처리	학습·평가 데이터에서 분할 전에 제거 . 버리지 않고 "기존 방화벽 규칙과 사람 검수를 통과한 실제 공격" 평가 세트로 활용 예정

37건은 작은 표본이라 "정확도 100%"라고 주장하지 않고, "확인한 표본에서 오탐 없음"까지만 씁니다.

4. 학습용 데이터 구성 결과

단계	남은 건수
원본 → 4분류 매핑(모호·대상 외 제외)	794,054
라벨 오류 감사 요청 제거	763,774
같은 입력이 서로 다른 라벨로 나오는 요청 제거(고유 입력 336개)	439,414
완전 중복 제거 후 최종	265,939

분할	정상	SQL 주입	코드 주입	명령 주입	계
학습 70%	46,864	128,502	6,905	3,886	186,157
검증 15%	10,042	27,537	1,480	832	39,891
시험 15%	10,042	27,536	1,480	833	39,891

- **정상 요청은 반복이 극심합니다.** 원본 정상 약 49만 건이 고유 요청으로는 약 6.7만 건입니다(가장 흔한 "메인 페이지 요청" 하나가 약 30만 건).
- **시험 데이터의 정상은 10,042건**으로, 지난 보고에서 원본 건수로 추정한 약 7.9만 건보다 적습니다. 오탐률 1% 기준 지표는 문제없고, 0.1% 기준은 오탐 10건 규모로 겨우 성립합니다.
- **시험 데이터의 공격 비율은 74.8%**입니다. 실제 서비스(공격이 드물)와 반대이므로, 지난 보고대로 속도 이득은 공격 비율 조건을 함께 적어 재계산합니다.
- **명령 주입이 SQL 주입의 1/43**입니다. 소수 클래스 하나가 평균 지표를 흔들 수 있어, 우열 판단은 반드시 교차검증으로 합니다.

5. 입력 필드 선택 실험

이 데이터는 실제 HTTP 요청이라, 이미지(48×48 = 2,304바이트)에 어떤 필드를 넣을지를 먼저 정해야 합니다. 결과를 보기 전에 실행 목록과 채택 규칙을 문서에 고정했고, **시험 데이터 15%는 열지 않은 채** 학습+검증 데이터(226,048건)만으로 5겹 교차검증을 했습니다(나중 본 측정이 이 선택에 오염되지 않게).

5.1 사전 측정 — 잘림은 일어나지 않음

URI·본문·쿠키·User-Agent를 모두 이어도 **최대 1,054바이트**로, 2,304바이트를 넘는 요청이 **0건**이었습니다. "긴 요청의 뒷부분이 잘려 공격이 사라진다"는 우려는 이 데이터에서는 해당하지 않습니다. 또 URI·본문 밖(쿠키·헤더)에만 공격 흔적이 있는 요청은 1% 미만이었습니다.

5.2 본 실험 — 이미지 CNN, 입력 조합 5종

입력	Macro-F1 (평균±표준편차)	오탐 1%일 때 탐지율	명령 주입 F1
URI	0.844 ± 0.008	0.876	0.541
URI + 본문 (현재)	0.895 ± 0.014	0.867	0.757
URI + 본문 + 쿠키	0.932 ± 0.018	0.850	0.852
URI + 본문 + 쿠키 + User-Agent	0.923 ± 0.025	0.831	0.839
대조군: User-Agent + 쿠키만	0.540 ± 0.054	0.113	0.157

5겹 교차검증, 모든 설정이 같은 분할을 공유(대응표본). 유의성은 대응표본 t-검정 + Holm 보정.

- **채택: URI + 본문 + 쿠키.** 필드가 더 적은 두 조합보다 유의하게 높았습니다(보정 $p = 0.020, 0.005$).
- **지름길 점검:** 쿠키·User-Agent만으로 학습한 대조 모델이 0.540에 그쳐, 사전에 정한 "0.90 이상이면 지름길로 보고 기각" 조건에 해당하지 않았습니다.

함께 보고할 주의점

- **오탐을 1%로 묶었을 때의 탐지율은 필드를 더할수록 오히려 낮아집니다**(0.876 → 0.831). 채택 기준(Macro-F1)과 운영 지표가 엇갈리므로 두 결과를 모두 신겠습니다.
- 향상의 대부분은 **명령 주입 구분**에서 나왔습니다. 쿠키 자체의 내용이 아니라 "쿠키가 있는가"가 신호일 가능성이 있어, 쿠키를 비운 입력으로 추가 확인하겠습니다.
- 가벼운 대리 모델(TF-IDF)로 미리 본 결과는 **반대 방향**이었습니다. 대리 결과로 정했다면 틀렸을 것이라, 판정은 본 실험으로만 한다는 원칙을 유지합니다.

6. 새로 드러난 한계

학습 데이터의 "정상"은 실제 사용자 트래픽이 아닙니다. 실제 사용자 브라우저에서 온 정상 요청 약 37.9만 건은 고유 요청으로 3,666개뿐이었고, 중복을 뺀 뒤 남은 정상 요청의 약 98%는 **공격 스캐너가 사이트를 돌며 보낸 정상 형태의 요청**이었습니다. 따라서 모델이 배우는 경계는 "공격 대 실사용자"보다 **"스캐너의 공격 요청 대 스캐너의 탐색 요청"**에 가깝습니다.

이에 따라 논문에서 오탐률을 **"실운영 오경보율"**로 쓰지 않고 "스캐너 탐색 트래픽 기준"으로 한정하며, 실사용자 출처 요청만 따로 떼어 오탐률을 병기하겠습니다.

7. 다음 계획

1. 텍스트 모델(문자 단위 CNN)로 같은 입력 조합 5종 교차검증 — 이미지 모델 결과와 병기 (GPU 약 4~5시간)

2. 학습 데이터 입력을 "URI + 본문 + 쿠키"로 전환하고, 쿠키를 비운 입력으로 지름길 여부 추가 확인
3. 이미지 모델·텍스트 모델·2단 구조 전체를 새 데이터에서 다시 측정(연구 질문 1·5부터)
4. 라벨 오류 감사로 걸러낸 "실제 공격" 세트에서 탐지율 측정

8. 여쭙고 싶은 것

Q1 정상 트래픽의 한계를 어떻게 다룰까요?

(가) 현재 데이터 안에서 실사용자 출처 정상 요청(고유 3,666개)의 오탐률을 따로 보고하는 선에서 한계로 명시한다 / (나) 다른 공개 데이터의 실사용자 정상 트래픽을 보강한다. (나)는 데이터 출처가 섞이는 새 문제가 생겨, 저희는 (가)를 우선 생각하고 있습니다.

Q2 채택 기준 지표와 운영 지표가 엇갈릴 때

입력 필드 실험처럼 Macro-F1(클래스 구분)과 저오탐 탐지율(운영)이 반대로 움직일 때, 논문의 주 결론은 어느 쪽을 기준으로 삼는 것이 좋을지 의견을 여쭙고 싶습니다.